

Use case for SSO awareness in Fedora

Swithun Crowe
University of St Andrews
cs2@st-andrews.ac.uk

March 30, 2011

Abstract

A use case for how Fedora, using a ServletFilter, can become aware of a SSO provider, and use it for authentication and authorization.

1 Goal

To enable users with access to a Single Sign On (SSO) system to use their SSO credentials in order to log into Fedora.

Many institutional users will have SSO provided by their institution. It would be nice if institutional repositories could make use of this to authenticate (AuthN) users and obtain authorization (AuthZ) information.

A ServletFilter would intercept the request for a resource, and look for AuthN and AuthZ information. This would be put into request attributes, and passed on down the filter chain, for use by other filters which handle AuthZ, e.g. the PEP filter. The particular pieces of information would be configurable, as different institutions and different SSO systems have different ways of passing on AuthN/AuthZ information, e.g. via application-specific HTTP headers or cookies.

A common use would be for an institutional repository to use an institution's Shibboleth service provider for authenticating users, and for using group or role information, provided by Shibboleth, to authorize access to resources as specified in XACML documents.

2 Actors

The principal actors in such a scenario would be a Fedora repository, a Single Sign On system, and users of both systems.

3 Preconditions

It is assumed that there will be a working SSO system in place already, which authenticates users and passes on authorization information. Also, Fedora should have XACML AuthZ enabled.

4 Success

A successful outcome would be for the Fedora repository to use an upstream SSO to authenticate users and obtain authorization information from the SSO which could then be used at the PEP level where XACML documents describe who can do what with particular repository objects.

Fedora would not need to maintain its own lists of user credentials, and could make use of institution wide user attributes, like groups and roles.

5 Sub-variations

Fedora has other AuthN/AuthZ methods (XMLUserFile, LDAP etc.), both in legacy servlet filters and the new Fedora Security Layer (FeSL) filters which use JAAS. A filter which makes Fedora aware of SSO AuthN/AuthZ should be able to work with or without FeSL enabled. Such a filter may not be the only AuthN/AuthZ filter - it is useful to have some special users hard coded into an XMLUserFile, for example.

6 Open

It isn't clear whether Fedora should try to handle caching (of users' AuthN/AuthZ information) issues, or simply rely on the upstream SSO for that. Performance may be improved with caching, but this may open security problems and introduce extra dependencies and complexity.